

category: database

tags: [sql-injection, security, legacy-code, avalonia-migration]

severity: critical

created: 2026-06-26

updated: 2026-06-26

project-origin: iPGSv4 CCU Avalonia migration

SQL Injection trong legacy FillData() pattern — không bị bắt khi build trên Windows

Tình huống gặp phải

Đang migrate WinForms → Avalonia (iPGSv4). Các ViewModel mới gọi method `FillData(string sql)` là legacy method nhận raw SQL string. Username và các ID từ DB/user input được nối thẳng vào chuỗi SQL bằng string interpolation (`$"... WHERE username='{Username}'"`) — compile fine trên Windows, không có warning.

Triệu chứng / Lỗi

Không có triệu chứng gì ở build/runtime trên Windows. Lỗi chỉ bị phát hiện khi code review chủ động tìm pattern string concatenation vào SQL.

Input `Username = "admin' OR '1'='1"` sẽ bypass authentication.

Nguyên nhân gốc rễ (Root Cause)

1. **Legacy method `FillData(string sql)`** không dùng parameterized query — thiết kế từ thời WinForms, không được refactor.
2. **Trong WinForms**, username thường chỉ đến từ TextBox do admin nhập trực tiếp → risk thấp hơn, không được review kỹ.
3. **Khi migrate sang MVVM**, Developer coi `FillData()` là black box và tập trung vào UI binding, không phân tích input flow bên trong.
4. **Không có security review step** trong WF-BUGFIX/WF-FEATURE workflow — chỉ có functional review.
5. **Compiler không cảnh báo** string interpolation vào SQL — CS0618 và CA1416 có thể bắt một số vấn đề nhưng không bắt injection.

Giải pháp

Khi `FillData()` không thể refactor ngay (legacy dependency), escape single quote trên mọi string nguồn từ user/DB trước khi đưa vào SQL:

```
// Pattern bắt buộc cho mọi string vào FillData():
string safeUser = Username.Replace("'", "''");
string safePass = CryptographyEnginePassword.Hash>Password).Replace("'", "''");
```

```
string cmd = $"SELECT ... WHERE username = '{safeUser}' AND password = '{safePass}'";  
FillData(cmd);
```

Áp dụng tương tự cho ID từ DB:

```
// Trong PollZcu(), PollSimple():  
string safeId = item.Id.Replace("'", "'");  
$"SELECT ... WHERE id='{safeId}'"
```

Áp dụng lại (How to reuse)

- Khi thấy `FillData(string)` hoặc bất kỳ method nào nhận raw SQL → **kiểm tra ngay tất cả nơi gọi method đó**.
- Sau khi migrate bất kỳ ViewModel nào có query DB → `grep FillData\ ( và $" hoặc +` trong cùng câu SQL.
- Rule: **mọi string user-controlled hoặc DB-controlled** vào SQL raw **PHẢI** `.Replace("'", "'')`
- Ưu tiên refactor sang parameterized query khi có thời gian.

Chú ý / Cạm bẫy (Gotchas)

- ⚠ `Replace("'", "'')` là biện pháp tạm thời — KHÔNG bảo vệ chống mọi kiểu injection (numeric column, LIKE wildcard). Chỉ dùng khi không thể parameterize ngay.
- ⚠ Password đã hash trước khi escape — đảm bảo `Hash()` chạy trước `Replace()` để không mất entropy.
- ⚠ Không chỉ escape Username — cần escape **mọi** string vào SQL từ nguồn bên ngoài (ID từ list, search term, v.v.).

Tham chiếu

- Files đã fix: `IPGSv4/ViewModels/LoginViewModel.cs`, `iPGS.Monitor/ViewModels/MonitorViewModel.cs`
- Project: iPGSv4 CCU, branch ccu-avalonia